



ZÁKLADY KYBERNETICKÉ BEZPEČNOSTI I.

Ing. Miroslav Bureš

Obsah

- Kyberprostor
- Soukromí v kyberprostoru
- Kybernetická kriminalita
- Kybernetická válka x kyberterorismus
- Legislativní základ kybernetické bezpečnosti
- CERT/CSIRT týmy

KYBERPROSTOR

Kyberprostor

<https://www.menti.com/isok92wnrn>



Definice kyberprostoru

„Konsenzuální halucinace prožívaná denně miliardami legitimních operátorů, v každém národě, dětmi, které se učí matematickým pojmům... grafické zobrazení dat abstrahovaných z pamětí každého počítače v lidské společnosti. Nepředstavitelná komplexita. Linie světla rozprostírající se v neprostoru mysli, klastry a konstelace dat. Jako světla velkoměsta, vzdalující se..."

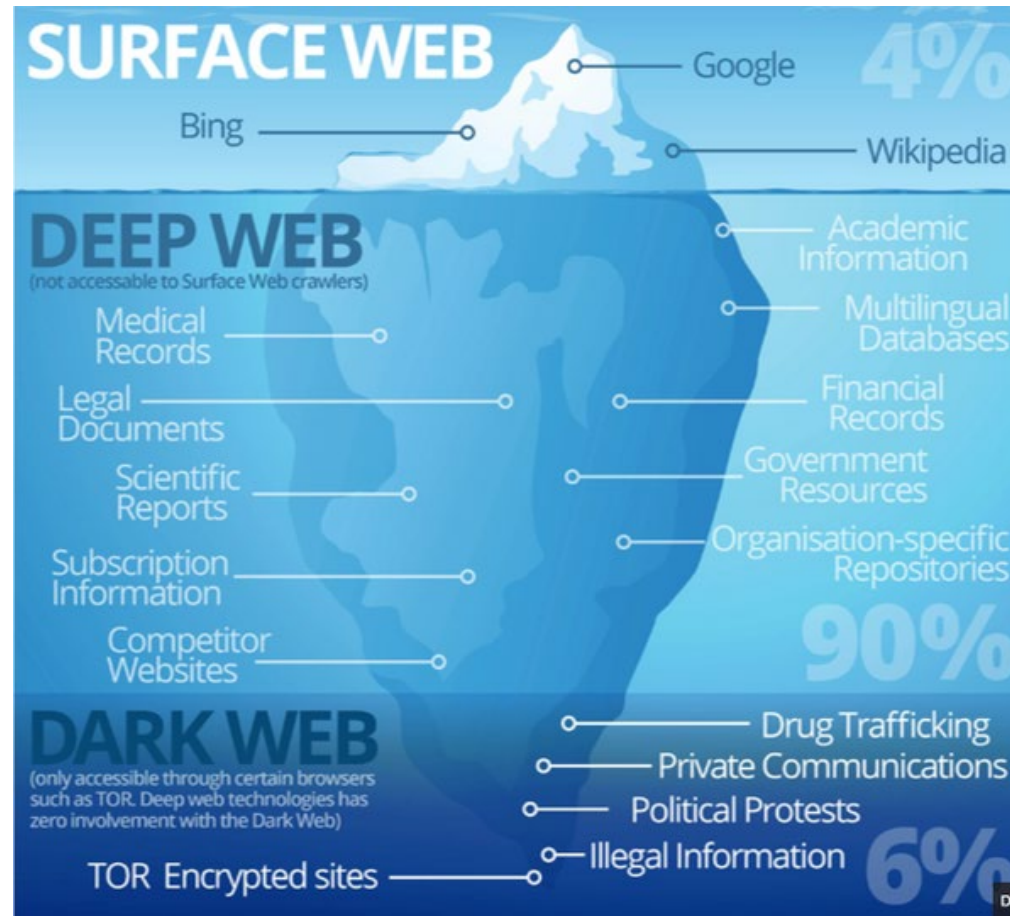
Definice kyberprostoru

"Kyberprostor je globální a vyvíjející se doména popisovaná užíváním elektrických sítí a elektromagnetického spektra, jejíž smysl je vytvářet, uchovávat, upravovat, vyměňovat, sdílet, vybírat, používat či vymazávat informace. Kyberprostor zahrnuje: a) fyzická i telekomunikační zařízení, která umožňují spojení technologií a komunikaci sítí systému, chápáno obecně (SCADA zařízení, smartphony/tablety, počítače, servery, atd..), b) počítačové systémy a komplementární software, který zaručuje spojení a funkčnost systému, c) spojení počítačových sítí, d) uživatelské vstupy a uzly zprostředkovatelů spojení, e) informace – uživatelská data."

Definice kyberprostoru

„Digitální prostředí umožňující vznik, zpracování a výměnu informací, tvořené informačními systémy, a službami a sítěmi elektronických komunikací“

Kyberprostor



<https://twitter.com/riccaraws/>

Kybernetická bezpečnost

„Souhrn právních, organizačních, technických a vzdělávacích prostředků směřujících k zajištění ochrany kybernetického prostoru.“

Základní principy kybernetické bezpečnosti



Triáda CIA

- Důvěrnost (Confidentiality)
 - k informacím, datům, či ICT mají přístup pouze subjekty, které jsou k tomu autorizované (oprávněné)
- Integrita (Integrity)
 - nemožnost zásahu do informací, dat, počítačových systémů, jejich nastavení atp. jinou osobou, než tou, která je k takovému úkonu oprávněna
- Dostupnost (Availability)
 - vlastnost přístupnosti a použitelnosti na žádost oprávněné entity

Prvky kybernetické bezpečnosti

- 1 **Lidé**
- 2 **Technologie**
- 3 **Procesy**

Bruce Schneier

„People often represent the weakest link in the security chain and are chronically responsible for the failure of security systems.“

„If you think technology can solve your security problems, then you don't understand the problems and you don't understand the technology.“

„The mantra of any good security engineer is: ‚Security is not a product, but a process.‘ It's more than designing strong cryptography into a system; it's designing the entire system such that all security measures, including cryptography, work together.“

Lidé

- strůjce (tvůrce) kybernetické bezpečnosti
- příjemce pravidel kybernetické bezpečnosti
- subjekty, které je třeba chránit před kybernetickými útoky
- subjekty, které je třeba informovat a proškolit o pravidlech a principech kybernetické bezpečnosti
- riziko či hrozbu v rámci vytváření a udržování kybernetické bezpečnosti

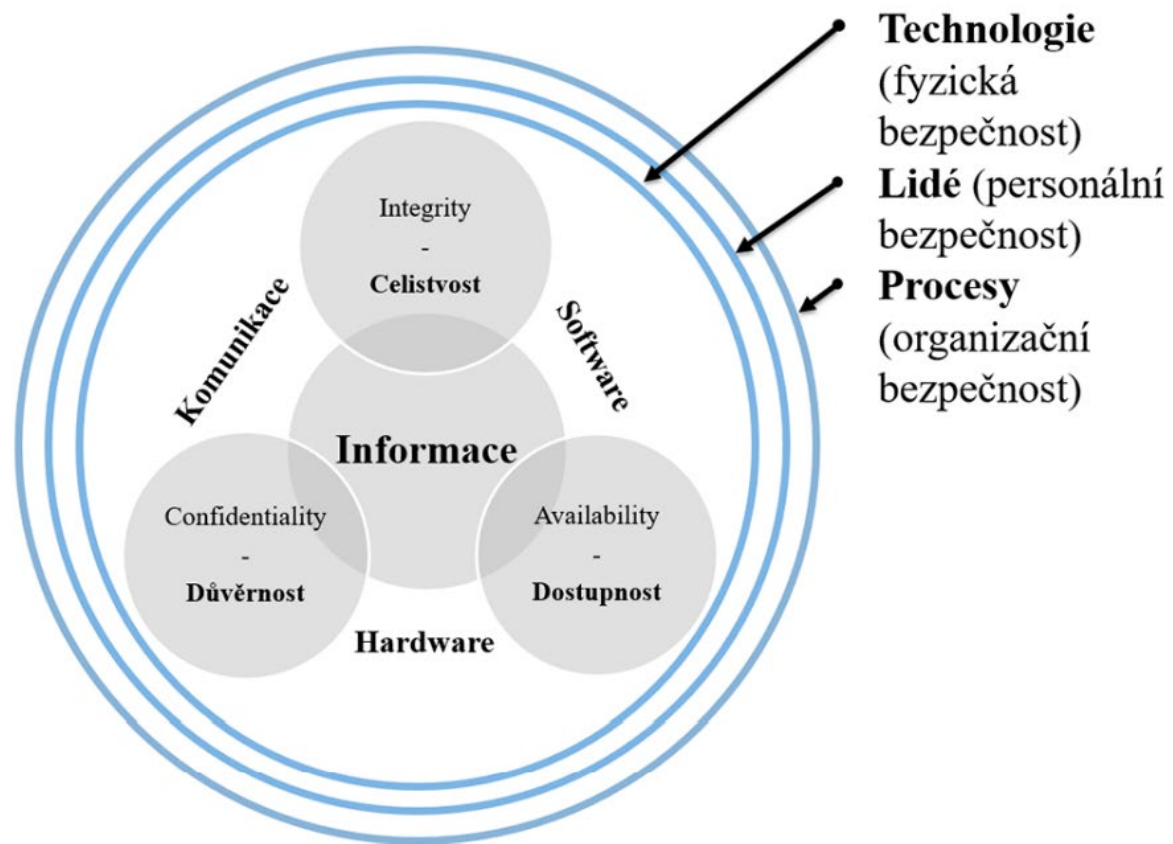
Technologie

- Detekční systémy - Intrusion Detection System (IDS)/Intrusion Prevention System (IPS)
- Centrální správa uživatelů a rolí
- Centralizovaná správa klasifikace informací
- Ochrana před škodlivým kódem (aplikační firewall, antivirové, antispamové a jiné řešení)
- Technologie pro zaznamenávání činností jednotlivých prvků ICT, administrátorů a uživatelů (log system)
- Aktivní a offline zálohovací systémy; zálohy vitálních serverů, aplikací a databází (recovery system)
- Správa síťové bezpečnosti (VLAN, DMZ, firewall aj.)

Procesy

- Řízení aktiv a rizik
 - definování a kategorizace aktiv
 - analýza a kategorizace rizik
- Implementace ICT a aplikací
- Správa uživatelů a rolí
- Autorizace a autentizace
- Údržby (aktualizace) systémů a služeb
- Testování zabezpečení jednotlivých počítačových systémů a služeb
- Analýza nápravných opatření
- Realizace nápravných opatření
- Audit kybernetické bezpečnosti
- Detekce anomálií či kybernetických útoků
- Reakce na kybernetické útoky či jiné incidenty
- Procesy k zajištění kontinuity
- Školení a cvičení atd.

Kybernetická bezpečnost



SOUKROMÍ V KYBERPROSTORU

Ochrana soukromí a osobních údajů

- Legislativa
 - GDPR (EU 2016/679)
 - Zákon 110/2019 Sb.
- Ztráta soukromí velmi často dobrovolná

GDPR - pokuty

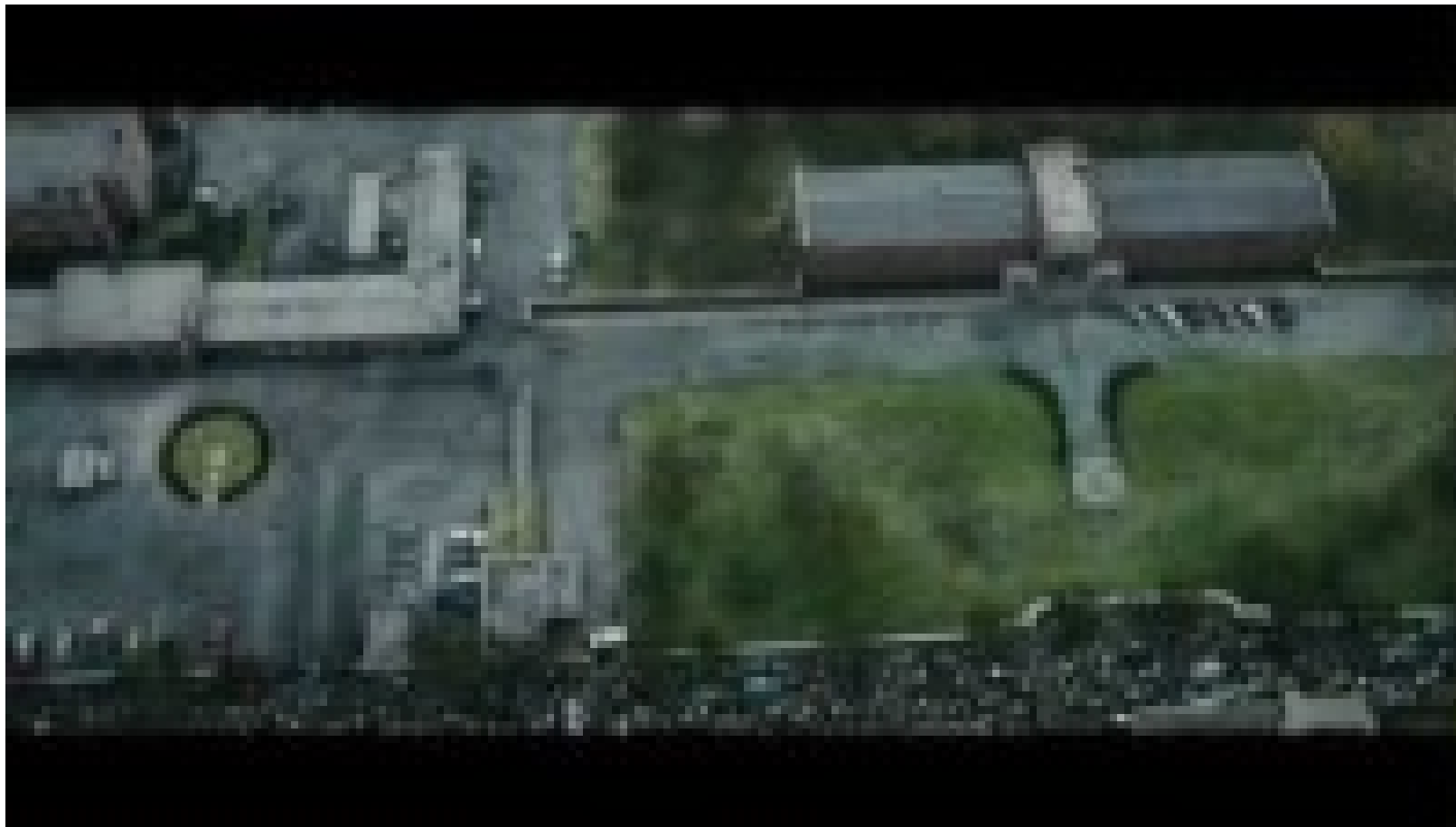
Month	Sum of Fines (up to month)	Number of Fines (up to month)
Oct 2020	€ 210,181,264	404
Nov 2020	€ 228,603,193	434
Dec 2020	€ 244,172,738	491
Jan 2021	€ 261,742,888	522
Feb 2021	€ 263,504,438	556
Mar 2021	€ 278,682,563	603
Apr 2021	€ 281,172,583	636
May 2021	€ 288,259,452	671
Jun 2021	€ 294,811,052	705
Jul 2021	€ 1,049,895,252	752
Aug 2021	€ 1,052,337,852	773
Sep 2021	€ 1,289,051,052	808
Oct 2021	€ 1,289,143,052	815

[GDPR Enforcement Tracker - list of GDPR fines](#)

Ochrana soukromí a osobních údajů

- Problematika likvidace dat
 - Vysoce komplexní globální aplikace
 - Data v cloudu
 - Zálohy dat (pravidlo 3-2-1)

Ochrana soukromí a osobních údajů



Smazání dat z internetu

- Internet má velmi dobrou paměť
 - Vyhledávače bez přestání indexují stránky
 - Záznamy uložené v cache paměti
 - Archive.org



Hledání dat na internetu

- Google
- Maltego
- HaveIBeenPwned.com
- Whois
- ...

Data zanechávaná na síti

- Není možné obecně říct, co který systém loguje (na straně serveru)
- Cílené reklamy ukazují, co se dá získat snadno
- <http://kyberbezpecnost.forbes.cz/>
- <https://clickclickclick.click/>

Cover Your Tracks - Panopticklick

- <https://coveryourtracks.eff.org/>

Data ukládaná bez vědomí uživatele

- Kam se posílají data při procházení internetem?
- Data na straně mobilních operátorů
 - Lokační data 24/7
 - Síťová komunikace
 - Profil chování

Soukromí přenášených dat

- Při připojení přes sítě nebo proxy servery třetích strany potenciální úniky dat
- SSL/TLS dekrypce na úrovni webových proxy
- Wi-Fi sniffing

Lokálně ukládaná data

- Cookies
- Logy operačního systému a aplikací
- Historie prohlížení webových stránek
- Cache webových stránek
- Logy, záznamy a cache dalších aplikací
- Dohromady se síťovými záznamy možné analyzovat

Problematická data

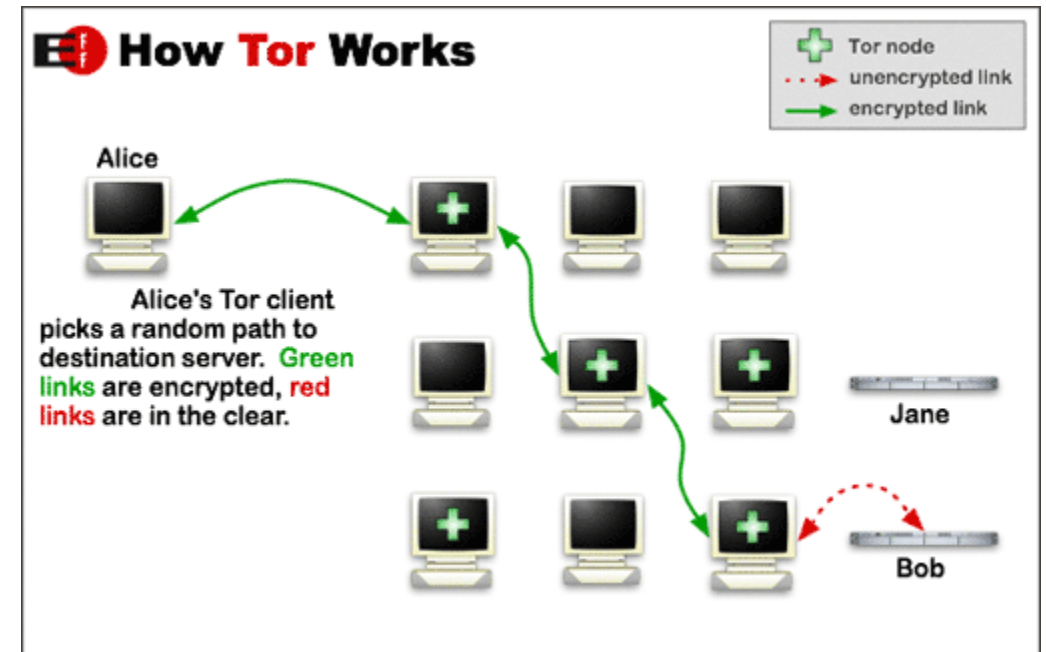
- Osobní údaje na síti
 - Google, Apple, sociální sítě
- Naše soubory na síti
 - Dropbox, Google Drive, OneDrive
- Finanční údaje na síti
 - E-shopy a e-banking

Sdělování citlivých informací

- Vytvoření důvěryhodného prostředí
- VPN (DH a bezpečná výměna klíčů)
- SSL/TLS, SSH
- Šifrování dat (e-mail, soubory)
- Sociální sítě a IM (Signal)

Anonymita v kyberprostoru

- Obecně problematická – dvě úrovně
 - Vysoká míra vnímané anonymity
 - Problematické reálné zajištění
- Šifrovaná komunikace
 - VPN
 - TOR
 - Proxy
 - E-mail



KYBERNETICKÁ KRIMINALITA, KYBERNETICKÁ VÁLKA A KYBERTERORISMUS

Státní suverenita v kyberprostoru

- Internet je globální síť
- Řízení provozu „na hranicích“ je extrémně složité až nemožné
- Monitoring určitých spojení potenciálně možné, ne však vždy
- V ČR projekt FENIX

Státní suverenita v kyberprostoru

- Extrémně složitá atribuce
 - Aktivita řízené z jednoho státu se provádějí v jiném státě a potenciálně mají vliv na jeden či více dalších států
 - Použitím proxy serverů, TOR, VPN a dalších faktorů je lokalizace skutečného zdroje komunikace často v podstatě nemožná (Ruska federace)

Státní suverenita v kyberprostoru

- Legislativně velmi problematické řešení škodlivé aktivity
 - Neexistuje možnost přímo postihnout nebo omezit aktéra mimo geografické území státu
- Velmi složitá přeshraniční spolupráce i v rámci EU

Kybernetická kriminalita

„Trestná činnost, v níž figuruje určitým způsobem počítač jako souhrn technického a programového vybavení (včetně dat), nebo pouze některá z jeho komponent, případně větší množství počítačů samostatných nebo propojených do počítačové sítě, a to buď jako předmět zájmu této trestné činnosti (s výjimkou té trestné činnosti, jejímž předmětem jsou popsána zařízení jako věci movité) nebo jako prostředí (objekt) nebo jako nástroj trestné činnosti “

Kybernetická kriminalita

„Často se pojem počítačová kriminalita používá i pro tradiční formy kriminality, u níž byly počítače nebo počítačové sítě použity, aby ji usnadnily. Určujícím operacionálním elementem je přitom vždy způsob zneužití výpočetní techniky, vzhledem k jejím specifickým vlastnostem a dominantnímu postavení mezi věcnými komponentami způsobu páchání konkrétního trestného činu.“

Kybernetická kriminalita

- Porušení CIA cizího systému/dat
- Protiprávní jednání, k němuž je využito funkci či potenciálu ICT
- Mnoho taxonomií

Kybernetická kriminalita

- Trestní zákoník (40/2009 Sb.)
 - § 182 - Porušení tajemství dopravovaných zpráv
 - § 230 - Neoprávněný přístup k počítačovému systému a nosiči informací
 - § 231 - Opatření a přechovávání přístupového zařízení a hesla k počítačovému systému a jiných takových dat
 - § 232 - Poškození záznamu v počítačovém systému a na nosiči informací a zásah do vybavení počítače z nedbalosti
 - § 270 - Porušení autorského práva, práv souvisejících s právem autorským a práv k databázi

Kybernetická kriminalita

- EU Convention on Cybercrime (2001)
 - Illegal access
 - Illegal interception
 - Data interference
 - System interference
 - Misuse of devices
 - Computer-related forgery
 - Computer-related fraud
 - Offences related to child pornography
 - Offences related to infringements of copyright and related right
 - ...

Kybernetická kriminalita

Parametr	Průměrné ozbrojené přepadení	Průměrný kybernetický útok
Riziko	Pachatel riskuje, že bude zraněn či zabit.	Bez rizika fyzické újmy
Zisk	Průměrně 3–5 tisíc USD.	Průměrně 50–500 tisíc USD.
Pravděpodobnost dopadení	Dopadeno 50–60 % útočníků.	Dopadeno cca 10 % útočníků.
Pravděpodobnost odsouzení	Odsouzeno 95 % dopadených útočníků.	Z dopadených útočníků dojde k soudnímu projednávání pouze u 15 % útočníků a z nich je odsouzeno jen 50 %.
Trest	Průměrně 5–6 let, pokud pachatel při loupeži nikoho nezranil.	Průměrně 2–4 roky.

JIROVSKÝ, Václav. Kybernetická kriminalita nejen o hackingu, crackingu, virech a trojských koních bez tajemství. Praha: Grada, 2007, s. 30

Sociální inženýrství

- Sociální inženýrství = forma manipulace
- Cílem je získání přístupu nebo informací
- Útoky realizované fyzicky nebo vzdáleně (telefon, e-mail, apod.)
- Jedinou ochranou je **dobře vyškolený a uvědomělý člověk**

Sociální inženýrství

- Phishing
 - Vishing
 - SMishing
 - Spear Phishing
 - Whaling

Sociální inženýrství

- Pretexting
- Tailgaiting/piggybacking
- Baiting
- Quid Pro Quo
- Vendor scam
- Device Leave Behind

Malware

- Co je malware?
 - Složenina anglických slov malicious software – škodlivý software
 - Neexistuje všeobecně přijímaná definice
 - Za malware, je možné označit jakýkoli software využitý k narušení standardní činnosti počítačového systému, zisku informací (dat), či využitý k získání přístupu k počítačovému systému.

Dělení malware

- Dle metody šíření
 - Virus
 - Červ
 - ...
- Dle payloadu
 - Ransomware
 - Kryptominer
 - ...

Obečné dělení malware

- Malware
 - Viry
 - Červy
 - Trojské koně
 - Ostatní malware
 - Exploity
 - Rootkity
 - Adware
 - Spyware
- 
- Hybridy

Viry

- Každý virus se skládá minimálně ze 2 částí
 - Vyhledávací rutina (nalezení cíle)
 - Kopírovací rutina (rozšíření)
- Viry je možné dělit, mj. dle
 - Infekčního vektoru a formy existence
 - Ochrany před detekcí

Rozdělení virů podle infekčního vektoru

- Viry

- Bakterie
- Sektorové viry
- Boot viry
- Makroviry
- Multiplatformní viry
- Cluster viry



Rozdělení virů podle ochrany před detekcí

- Šifrované viry
- Stealth viry
- Polymorfní viry
- Anti-antiviry
- Retro viry
- Obrněné viry
- Oligomorfní viry
- Metamorfní viry

Červi

- Na rozdíl od virů neparazitické
- Zpravidla pouze jedna generace na jednom hostitelském PC
- Primárním vektorem počítačové sítě a síťové služby

Červi

- Mailer/MM
- Internetové
- Síťové
- IM/IRC



Trojské koně

- Dříve škodlivý kód vydávající se za kód jiný
- Dnes se používá pro libovolný malware neschopný replikace
- Pro šíření využívá externí mechanismus

Trojské koně

- Backdoory
- PWD-stealing
- Downloadery
- Key-loggery
- Droppery (keygen)
- Injektory
- Dialery
- Proxy

Exploit kity

- Distribuční mechanismus pro malware
 - MaaS
 - Drive-by stahování škodlivého kódu
 - Občasné využití reklam

Ransomware

Hacker způsobil benešovské nemocnici škodu 59 milionů, policie ho nedopadla

🕒 18. srpna 2020 9:12



Hackeri ochromili benešovskou nemocnici. Nelze spouštět přístroje, ruší se operace

Systém v benešovské nemocnici napadl ruský vir Ryuk

ANEŽKA ČERMÁKOVÁ, ČTK



Na nemocnici v Benešově útočil ruský virus Ryuk. Jermanová odmítá, že by někdo požadoval výkupné

Ransomware

Woman dies during a ransomware attack on a German hospital

It could be the first death directly linked to a cybersecurity attack

By [Nicole Wetsman](#) | Sep 17, 2020, 3:11pm EDT

<https://www.securityweek.com/german-hospital-hacked-patient-taken-another-city-dies>

[Computing / Cybersecurity](#)

A patient has died after ransomware hackers hit a German hospital

This is the first ever case of a fatality being linked to a cyberattack.

by **Patrick Howell O'Neill**

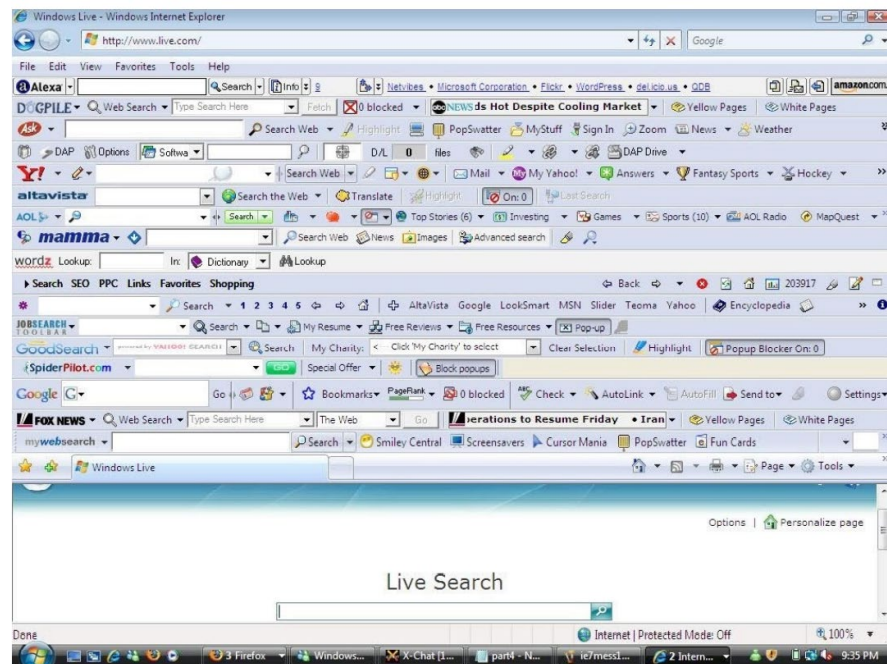
September 18, 2020

Ransomware

- Různé typy i cíle
 - PC a servery, tablety a telefony, televize, DB, ...
- Občas netradiční možnost dekrypce
 - Další rozšíření infekce na 2 počítače
 - Přečtení 2 článků o ransomware bezpečnosti
- Krádeže (zveřejňování/dražby) dat
- <https://www.nomoreransom.org/>

Další typy malware

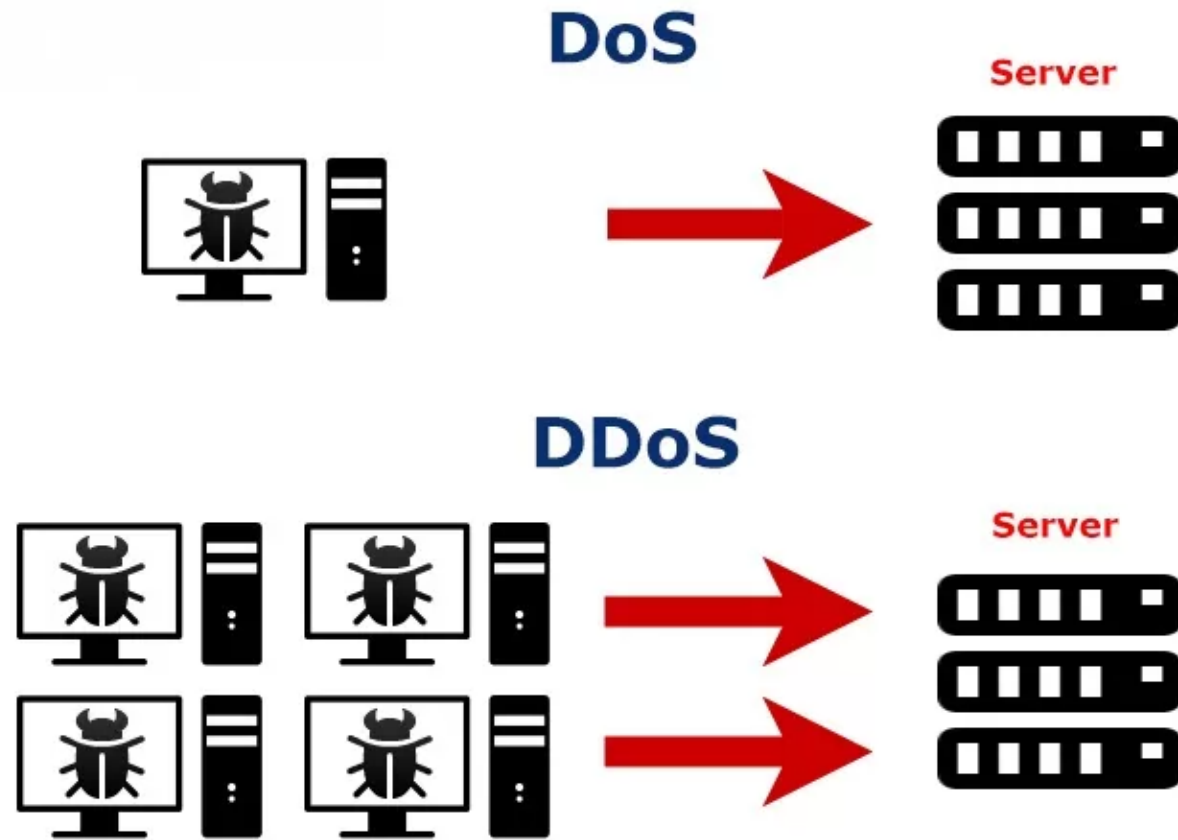
- Spyware
- Adware



Dos, DDoS

- Jedná se o jednu z forem útoků na (internetovou) službu, jehož cílem je vyřazení z činnosti nebo snížení výkonu napadeného technického zařízení
- DoS - Denial of Service
- DDoS - Distributed Denial of Service

DoS, DDoS



Botnet

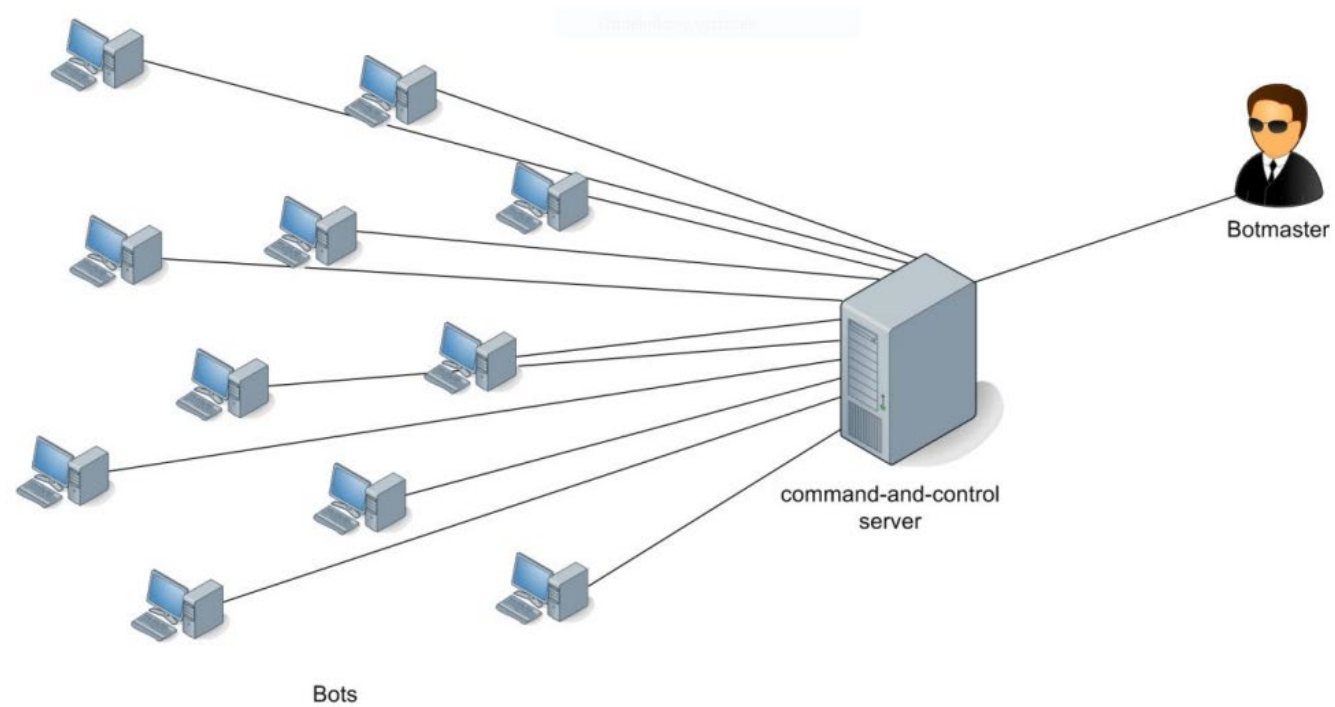
- „Sít' softwarově propojených botů, které provádí činnost na základě příkazu „vlastníka“ (resp. správce) této sítě. Takto postavená síť může být použita k legální činnosti (např. distribuované výpočty), nebo k činnosti nelegální“
- Struktura botnetů
 - Bootmaster
 - Command-and-control infrastructure
 - Bots

Botnet



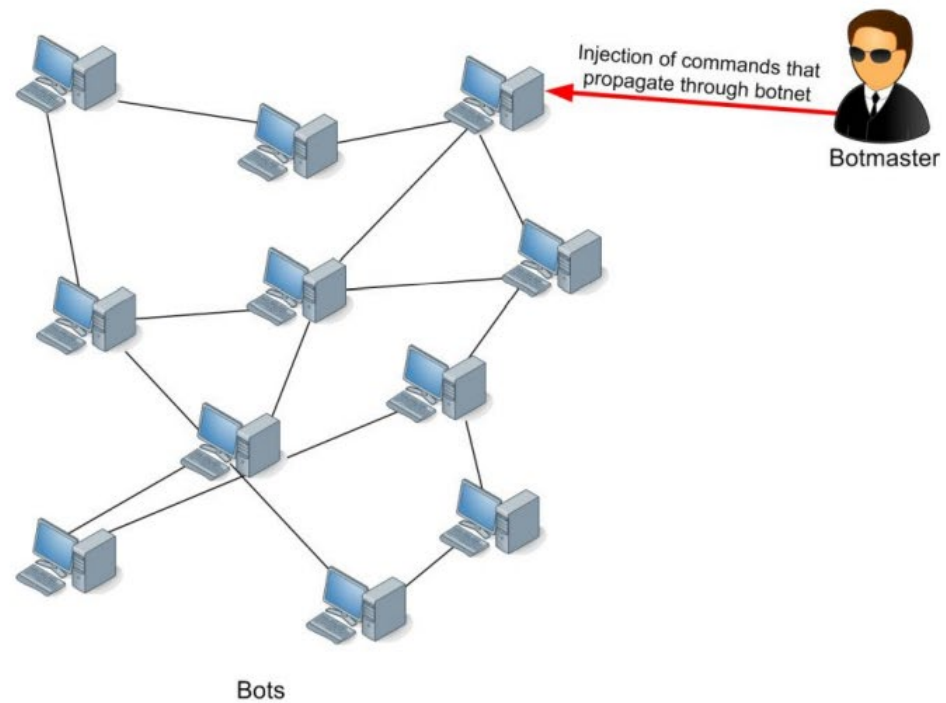
Botnet

Centralizovaná architektura



Botnet

Decentralizovaná architektura



Kybernetický terorismus

- Neexistuje obecně přijímaná definice
- „one man's terrorist ...“
- Za KT považováno (dle definice) vše od činů vedoucích k poškození/vyřazení systémů či infrastruktury po jakékoliv akty využívající ICT, které vedou ke vzbuzení strachu v populaci

Kybernetický terorismus

„The use of computer network tools to shut down critical national infrastructures (e.g., energy, transportation, government operations) or to coerce or intimidate a government or civilian population. “

Kybernetický terorismus

„The intimidation of civilian enterprise through the use of high technology to bring about political, religious, or ideological aims, actions that result in disabling or deleting critical infrastructure data or information. “

Kybernetický terorismus

„The use of information technology by terrorist groups and individuals to further their agenda. This can include use of information technology to organize and execute attacks against networks, computer systems and telecommunications infrastructures, or for exchanging information or making threats electronically. Examples are hacking into computer systems, introducing viruses to vulnerable networks, web site defacing, Denial-of-service attacks, or terroristic threats made via electronic communication“

Kybernetický terorismus

- Časté útoky
 - Defacement
 - (D)DoS
 - Prolomení e-mailových účtů
 - Prolomení účtů na sociálních sítích
 - Snahy o útoky na kritickou infrastrukturu
 - Krádeže dat

Kybernetický terorismus

- Ardit Ferizi
 - Obviněn v říjnu 2015 v USA z „kyberterorismu“
 - Realizoval krádeže dat (e-mailové adresy, hesla, fyzické umístění, telefonní čísla) vojenského personálu
 - Data předával ISIS – identity zveřejněny online se záměrem fyzické likvidace daných osob

Kyberválka

- V červenci 2016 NATO oficiálně označilo kyberprostor za pátou válečnou doménu
- Talinský manuál
 - Tallinn Manual on the International Law Applicable to Cyber Warfare
 - Nezávazná právní studie vytvořená mezinárodním kolektivem na žádost NATO CCDCoE v Talinu
 - Interpretace mezinárodního práva ve vztahu k vojenským operacím v kyberprostoru
 - Hlavní
 - Verze 1.0 v roce 2013, verze 2.0 v roce 2017

Kyberválka

- Kybernetický útok a obrana
 - Extrémní problémy s atribucí útoků
 - Mnoho států má speciální jednotky pro špionážní a ofenzivní vojenské operace v kyberprostoru
- Obranu musí řešit všechny moderní státy
- V ČR má odpovědnost za kybernetickou obranu Vojenské Zpravodajství, za ofenzivní operace AČR a VZ

ZÁKON O KYBERNETICKÉ BEZPEČNOSTI

Právní normy vztahující se ke KB

- Dokumenty EU/ES sloužící k harmonizaci právních úprav při řešení problematiky kybernetické bezpečnosti
 - Listina základních práv Evropské unie
- Směrnice Evropského parlamentu a Rady
 - 2016/1148 o opatřeních k zajištění vysoké společné úrovně bezpečnosti sítí a informačních systémů v Unii (NIS)
- Nařízení Evropského parlamentu a Rady
 - 910/2014 o elektronické identifikaci a službách vytvářejících důvěru pro elektronické transakce na vnitřním trhu a o zrušení směrnice 1999/93/ES (eIDAS)
 - 679/2016 o ochraně fyzických osob v souvislosti se zpracováním osobních údajů a o volném pohybu těchto údajů a o zrušení směrnice 95/46/ES (obecné nařízení o ochraně osobních údajů - GDPR)
 - Návrh nařízení o respektování soukromého života a ochraně osobních údajů v elektronických komunikacích a o zrušení směrnice 2002/58/ES (nařízení o soukromí a elektronických komunikacích – ePrivacy)
- Další dokumenty
 - Úmluva Rady Evropy č. 185 o kybernetické kriminalitě
- Mezinárodní normy
 - ISMS řady ISO/IEC 27000

Právní související s kybernetickou bezpečností

- **Právní normy ČR**

- **Zákon č. 40/2009 Sb., trestní zákoník**
- Zákon č. 418/2011 Sb., o trestní odpovědnosti právnických osob a řízení proti nim
- Zákon č. 141/1961 Sb., o trestním řízení soudním
- Zákon č. 218/2003 Sb., zákon o soudnictví ve věcech mládeže
- **Zákon č. 121/2000 Sb., autorský zákon**
- **Zákon č. 127/2005 Sb., o elektronických komunikacích**
- Zákon č. 480/2004 Sb., o některých službách informační společnosti
- Zákon č. 273/2008 Sb., o Policii České republiky
- **Zákon č. 89/2012 Sb., občanský zákoník**
- Zákon č. 101/2000 Sb., o ochraně osobních údajů
- Zákon č. 14/1993 Sb., o opatřeních na ochranu průmyslového vlastnictví
- Zákon č. 441/2003 Sb., o ochranných známkách
- Zákon č. 527/1990 Sb., o vynálezech, průmyslových vzorech a zlepšovacích návrzích
- **Zákon č. 300/2008 Sb., o elektronických úkonech a autorizované konverzi dokumentů, ve znění pozdějších předpisů**
- Zákon č. 297/2016 Sb., o službách vytvářejících důvěru pro elektronické transakce
- Zákon č. 160/1999 Sb., o svobodném přístupu k informacím
- **Zákon č. 181/2014 Sb., o kybernetické bezpečnosti a o změně souvisejících zákonů (zákon o kybernetické bezpečnosti)**

Dokumenty určující KB v ČR

- Zákon č. 181/2014 Sb. - Zákon o kybernetické bezpečnosti a o změně souvisejících zákonů (zákon o kybernetické bezpečnosti)
- Vyhláška č. 82/2018 Sb. - Vyhláška o bezpečnostních opatřeních, kybernetických bezpečnostních incidentech, reaktivních opatřeních, náležitostech podání v oblasti kybernetické bezpečnosti a likvidaci dat (vyhláška o kybernetické bezpečnosti)
- Vyhláška č. 317/2014 Sb. - Vyhláška o významných informačních systémech a jejich určujících kritériích
- Nařízení vlády č. 315/2014 Sb. - Nařízení vlády, kterým se mění nařízení vlády č. 432/2010 Sb., o kritériích pro určení prvku kritické infrastruktury

NÚKIB

- Národní úřad pro kybernetickou a informační bezpečnost
- V rámci novely ZoKB došlo k odštěpení Národního Centra Kybernetické Bezpečnosti (NKCB) od NBÚ a vzniku nového samostatného úřadu

Zákon o kybernetické bezpečnosti

- Cíl, jehož se ZoKB snaží dosáhnout, je zajištění bezpečného fungování české informační společnosti, tj. zajištění bezpečné realizace základního práva na informační sebeurčení a ochrana nedistributivních práv státu
- Zákon o kybernetické bezpečnosti **nezakládá civilní ani trestní odpovědnost pachatelů kybernetických útoků**
- Zákon o kybernetické bezpečnosti vytváří systém bezpečnostních opatření, která mají výskytu kybernetických bezpečnostních incidentů předcházet, resp. která mají zajistit, že případný kybernetický bezpečnostní incident neohrozí celkové fungování informačních a komunikačních systémů nebo fungování kriticky důležitých společenských informačních funkcionalit

Cíle zákona o kybernetické bezpečnosti

- Definování základní úrovně bezpečnostních opatření
- Zavedení detekce kybernetických bezpečnostních událostí
- Zavedení hlášení kybernetických bezpečnostních incidentů
- Vytvoření systému protiopatření k reakci na kybernetické bezpečnostní incidenty
- Definování činnosti dohledových pracovišť (národní CERT a vládní CERT)

Zákon o kybernetické bezpečnosti

- Zákon 181/2014 Sb.
 - Kdo co musí dělat
 - Co se musí dělat
- Vyhláška 82/2018
 - Detail opatření
 - Dokumentace
 - Incident

Zákon o kybernetické bezpečnosti

- Hlava I - Základní ustanovení
 - Nevztahuje se na IS a KS s utajovanými informacemi
 - Zapracovává příslušné předpisy EU
 - Definuje terminologické pojmy
 - Určuje, na koho se vztahuje zákon, tzv. povinné osoby

Zákon o kybernetické bezpečnosti

- Povinné osoby
 - Poskytovatelé služby elektronických komunikací
 - Správci Významných informačních systémů (VIS)
 - Správci Kritické informační infrastruktury (KII)
 - Provozovatelé základních služeb (PZS)
 - Poskytovatelé digitálních služeb (DSP)

Zákon o kybernetické bezpečnosti

- Poskytovatelé služby elektronických komunikací
 - Týká se jich soubor pravidel daných ZoKB a Prováděcím právním předpisem
 - Mají Zákon o elektronických komunikacích
 - Komunikují s Národním CERTem
 - 12 měsíců překlenovací lhůta od účinnosti ZoKB, tj. od 1.1.2016
 - Dělí se na dvě skupiny
 - Poskytovatelé zajišťující přímé zahraniční připojení do veřejné sítě nebo přímo připojují KII
 - Ostatní poskytovatele

Zákon o kybernetické bezpečnosti

- Významné informační systémy (VIS)
 - Jsou definovány podle určujících kritérií uvedených ve Vyhlášce o významných informačních systémech
 - 12 měsíců překlenovací lhůta od naplnění určujících kritérií VIS
 - Týká se jich soubor pravidel daných ZoKB a Prováděcím právním předpisem
 - Komunikují s Vládním CERTem

Zákon o kybernetické bezpečnosti

- Kritická informační infrastruktura (KII)
 - Jsou definovány podle určujících kritérií uvedených v Nařízení vlády č. 315/2014 Sb.
 - 12 měsíců překlenovací lhůta od naplnění určujících kritérií KII
 - Týká se jich soubor pravidel daných ZoKB a Prováděcím právním předpisem
 - Komunikují s Vládním CERTem
 - Mají rozdělen Informační systém (IS) od Komunikačního systému (KS)

Zákon o kybernetické bezpečnosti

- Provozovatel základních služeb
 - Velmi podobný KII
 - Definice vyhláškou č. 437/2017 Sb.

Zákon o kybernetické bezpečnosti

- Poskytovatel digitálních služeb
 - Vhodná a přiměřená bezpečnostní opatření
 - Prováděcí nařízení komise (EU) 2018/151 určuje pravidla definice bezpečnostních opatření při zohlednění rizik
 - on-line tržiště, internetového vyhledávače, cloud computing

Zákon o kybernetické bezpečnosti

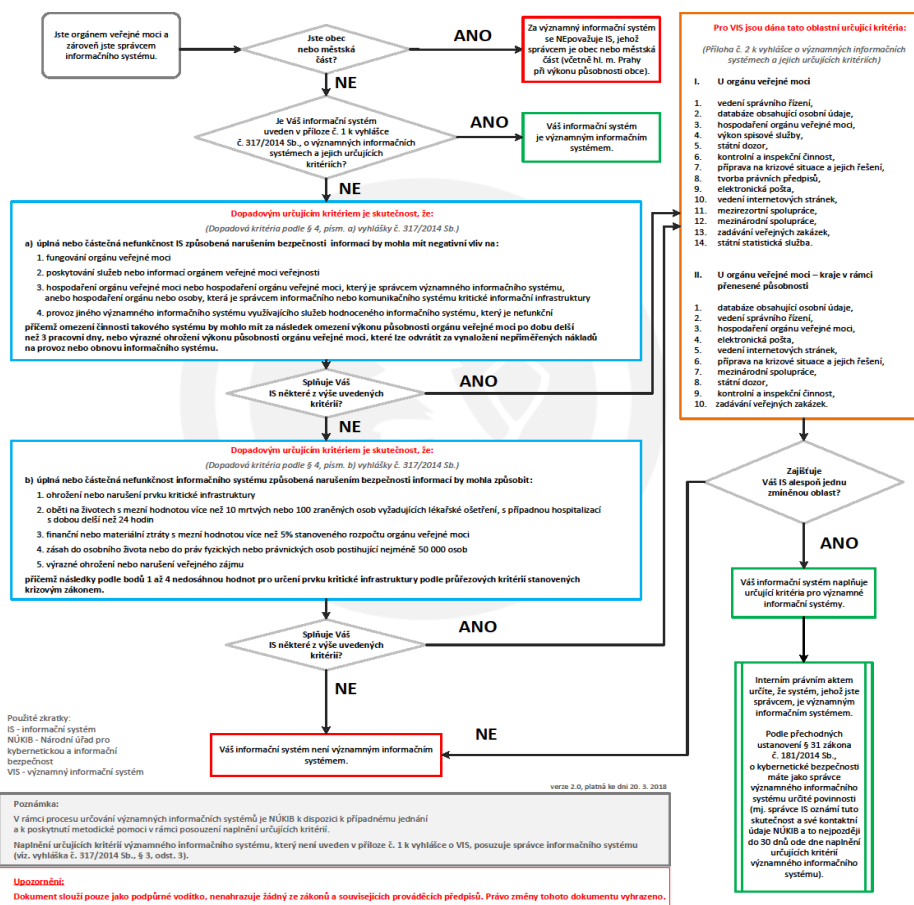
VIS → PZS → KII

Zákon o kybernetické bezpečnosti

Významné informační systémy

Proces určování podle vyhlášky č. 317/2014 Sb., o významných informačních systémech a jejich určujících kritériích

Národní úřad
pro kybernetickou
a informační bezpečnost



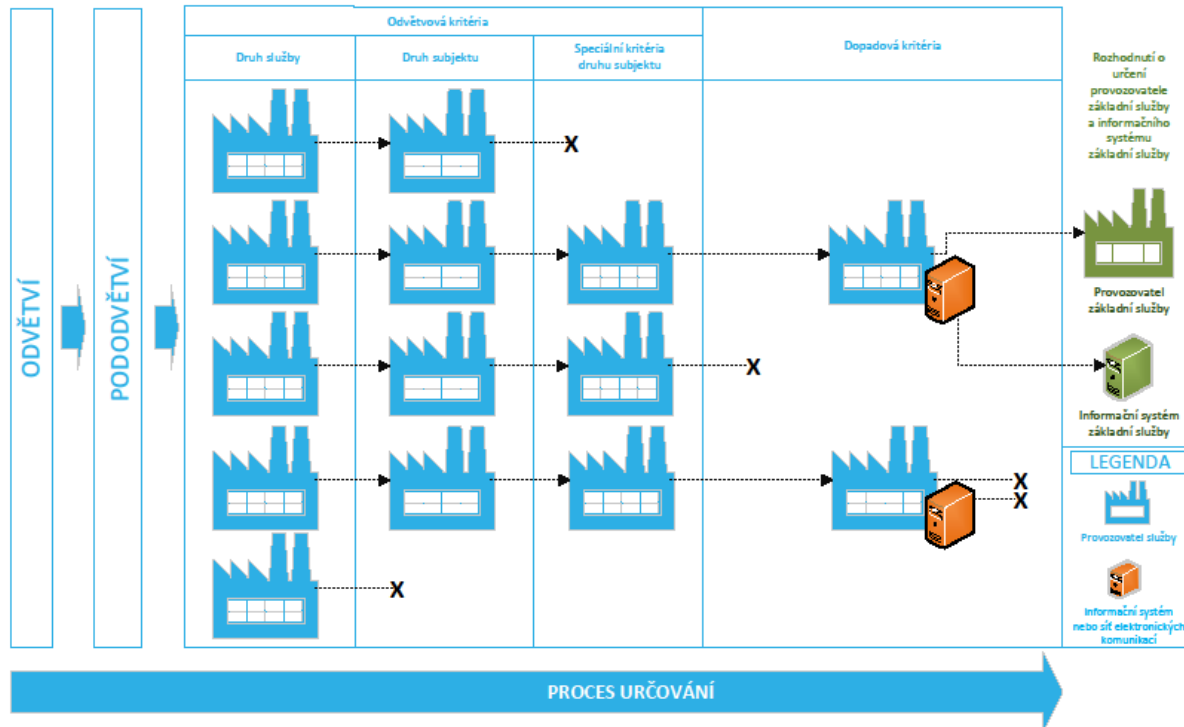
Zákon o kybernetické bezpečnosti

Základní služba

Národní úřad
pro kybernetickou
a informační bezpečnost



Proces určení provozovatele základní služby a informačního systému základní služby dle zákona o kybernetické bezpečnosti
a vyhlášky o kritériích pro určení provozovatelů základních služeb



Upozornění:

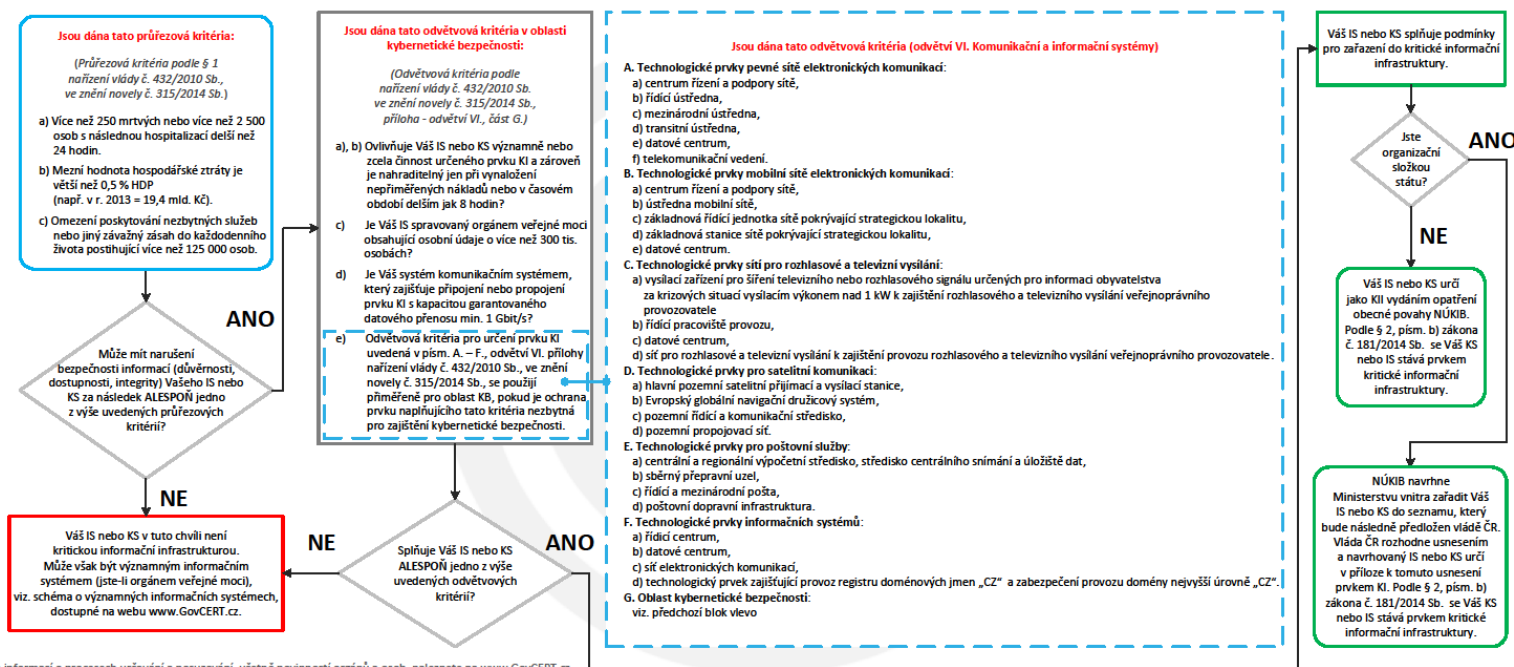
Dokument slouží pouze jako podpůrné vodítko, nenahrazuje žádný ze zákonů a souvisejících prováděcích předpisů. Právo změny tohoto dokumentu vyhrazeno.

Zákon o kybernetické bezpečnosti

Kritická informační infrastruktura

Proces určování podle zákona č. 240/2000 Sb., o krizovém řízení a o změně některých zákonů (krizový zákon) a nařízení vlády č. 432/2010 Sb., o kritériích pro určení prvku kritické infrastruktury ve znění novely č. 315/2014 Sb.

Národní úřad
pro kybernetickou
a informační bezpečnost



Více informací o procesech určování a posuzování, včetně povinností orgánů a osob, naleznete na www.GovCERT.cz

Použité zkratky: IS - informační systém, KB - kybernetická bezpečnost, KI - kritická infrastruktura, KII - kritická informační infrastruktura, KS - komunikační systém, NÚKIB - Národní úřad pro kybernetickou a informační bezpečnost, OOP - opatření obecné povahy

verze 2.0, platná ke dni 20. 3. 2018

Poznámka:

V rámci procesu určování kritické informační infrastruktury (KII) bude NÚKIB s dotčenými subjekty jednat a to již před samotným určením. Samotné určení pak proběhne, po oboustranném jednání. U organizačních složek státu probíhá určení prvku KII vydáním usnesení vlády ČR. U orgánů nebo osob, které nejsou organizační složkou státu, probíhá určení vydáním opatření obecné povahy (OOP), které vydá NÚKIB. NÚKIB je k dispozici k případnému jednání a k poskytnutí metodické pomoci v rámci posouzení naplnění určujících kritérií.

Upozornění:

Dokument slouží pouze jako podpůrné vodítko, nenahrazuje žádný ze zákonů a souvisejících prováděcích předpisů. Právo změny tohoto dokumentu vyhrazeno.

Zákon o kybernetické bezpečnosti

- Hlava II - Systém zajištění kybernetické bezpečnosti
 - Definuje povinnosti implementace bezpečnostních opatření
 - Popisuje KBU a KBI
 - Určuje způsob hlášení a evidence KBI
 - Stanovuje typy opatření před hrozbami a dopady KBI
 - Definuje práci s kontaktními údaji
 - Definuje, kdo je a co musí Národní/Vládní CERT

Zákon o kybernetické bezpečnosti

- Bezpečnostní opatření
 - Organizační opatření
 - Technická opatření

Zákon o kybernetické bezpečnosti

- Organizačními opatřeními jsou:
 - a) systém řízení bezpečnosti informací,
 - b) řízení rizik,
 - c) bezpečnostní politika,
 - d) organizační bezpečnost,
 - e) stanovení bezpečnostních požadavků pro dodavatele,
 - f) řízení aktiv,
 - g) bezpečnost lidských zdrojů,
 - h) řízení provozu a komunikací,
 - i) řízení přístupu osob,
 - j) akvizice, vývoj a údržba,
 - k) zvládání kybernetických bezpečnostních událostí a kybernetických bezpečnostních incidentů,
 - l) řízení kontinuity činností a
 - m) kontrola a audit.

Zákon o kybernetické bezpečnosti

- Technickými opatřeními jsou:
 - a) fyzická bezpečnost,
 - b) nástroj pro ochranu integrity komunikačních sítí,
 - c) nástroj pro ověřování identity uživatelů,
 - d) nástroj pro řízení přístupových oprávnění,
 - e) nástroj pro ochranu před škodlivým kódem,
 - f) nástroj pro zaznamenávání činnosti informačního nebo komunikačního systému, jeho uživatelů a administrátorů,
 - g) nástroj pro detekci kybernetických bezpečnostních událostí,
 - h) nástroj pro sběr a vyhodnocení kybernetických bezpečnostních událostí,
 - i) aplikační bezpečnost,
 - j) kryptografické prostředky,
 - k) nástroj pro zajišťování úrovně dostupnosti informací a
 - l) bezpečnost průmyslových a řídicích systémů.

Zákon o kybernetické bezpečnosti

- Kybernetická bezpečnostní událos (KBU)
 - Událost, která může způsobit narušení bezpečnosti
 - Není povinnost hlásit Národnímu/Vládnímu CERT
 - Je povinnost detekovat KBU u VIS a KII, a dále u poskytovatelů zajišťujících přímé zahraniční propojení do veřejné sítě nebo u těch, kde je přímo připojen KII a nově PZS (od novely v roce 2017)

Zákon o kybernetické bezpečnosti

- Kybernetická bezpečnostní incident (KBI)
 - Událost, která způsobila narušení bezpečnosti
 - Je povinnost hlásit Národnímu/Vládnímu CERTu bezodkladně po detekci
 - Prováděcí právní předpis stanovuje typy a kategorie KBI a formuláře pro hlášení
 - Evidenci KBI vede Vládní CERT
 - Zaměstnanci Vládního CERTu jsou vázáni mlčenlivosti pod sankcemi
 - Novinka – uložení povinnosti informovat veřejnost

Zákon o kybernetické bezpečnosti

- Opatření
 - Varování
 - Reaktivní opatření
 - Ochranné opatření

Zákon o kybernetické bezpečnosti

- Varování
 - O hrozbě v oblasti KB
 - Na webu Vládního CERTu + odeslání všem ovlivněným organizacím

Zákon o kybernetické bezpečnosti

- Reaktivní opatření
 - Musí být uloženo v souvislosti s ochrannou před KBI nebo k řešení KBI
 - Odesláno písemně, pokud do 3 dnů není doručení, následuje vyvěšení na úřední desce
 - Může být uloženo na místě ve správním řízení
 - Rozklad nemá odkladný účinek
 - U neurčité skupiny lze řešit opatřením obecné povahy
 - Ovlivněné organizace oznámí výsledek opatření
 - Způsob oznámení v Prováděcím předpisu

Zákon o kybernetické bezpečnosti

- Ochranné opatření
 - Na základě analýzy vyřešeného KBI nebo za účelem zvýšení bezpečnosti
 - Forma – Opatřené obecné povahy
 - Lhůta k provedení
 - Prakticky se jedná o dodatek k Prováděcímu právnímu předpisu

CERT/CSIRT TÝMY

CERT/CSIRT týmy

- Na počátku stál Morissův červ
- Vznik konec 80. let 20. století
- CERT - Computer Emergency Response Team
- CSIRT - Computer Security Incident Response Team

CERT/CSIRT týmy

„Tým, který je ve svém jasně definovaném poli působnosti zodpovědný za řešení bezpečnostních incidentů a (kyber) hrozeb, z pohledu uživatelů nebo jiných týmů tedy místo, na které se mohou obrátit se zjištěným bezpečnostním incidentem, se žádostí o spolupráci, výměnu informací, pomoc apod.“

CERT/CSIRT týmy

- Základní povinností každého CSIRT týmu je reakce na hrozbu („response“) a spolupráce při řešení incidentů
- Rozdíl mezi běžným bezpečnostním týmem a týmem typu CERT/CSIRT je zejména v zapojení do světové bezpečnostní infrastruktury, sdílení informací v rámci této infrastruktury a dodržování stanovených formálních postupů

CERT/CSIRT týmy

- Základním požadavkem komunity je, aby CERT/CSIRT tým veřejně deklaroval své kontaktní informace a pravidla činnosti:
 - kdo je jeho provozovatel
 - kdo jsou jeho členové
 - způsob jak a kdy je možné tým zastihnout
 - jaké **služby** nabízí
 - **pole působnosti** (číslo AS, síť, domény, služby), ve kterém je tým způsobilý konat a jakým způsobem, tzn. definování jeho pravomocí a odpovědnosti. Na základě pole působnosti je potom tým kontaktován (např. napadenými) a řeší jemu příslušející problémy (incidenty)

CERT/CSIRT týmy

- Typy CERT/CSIRT
 - Interní
 - Národní/Vládní
 - Koordinační
 - Vendor
 - Analytická centra
- Státní
- Akademické
- Komerční
- Odborné

CERT/CSIRT týmy

- Národní CERT
 - <https://csirt.cz/>
- Vládní CERT
 - <https://nukib.cz/cs/kyberneticka-bezpecnost/vladni-cert/govcert-cz/>

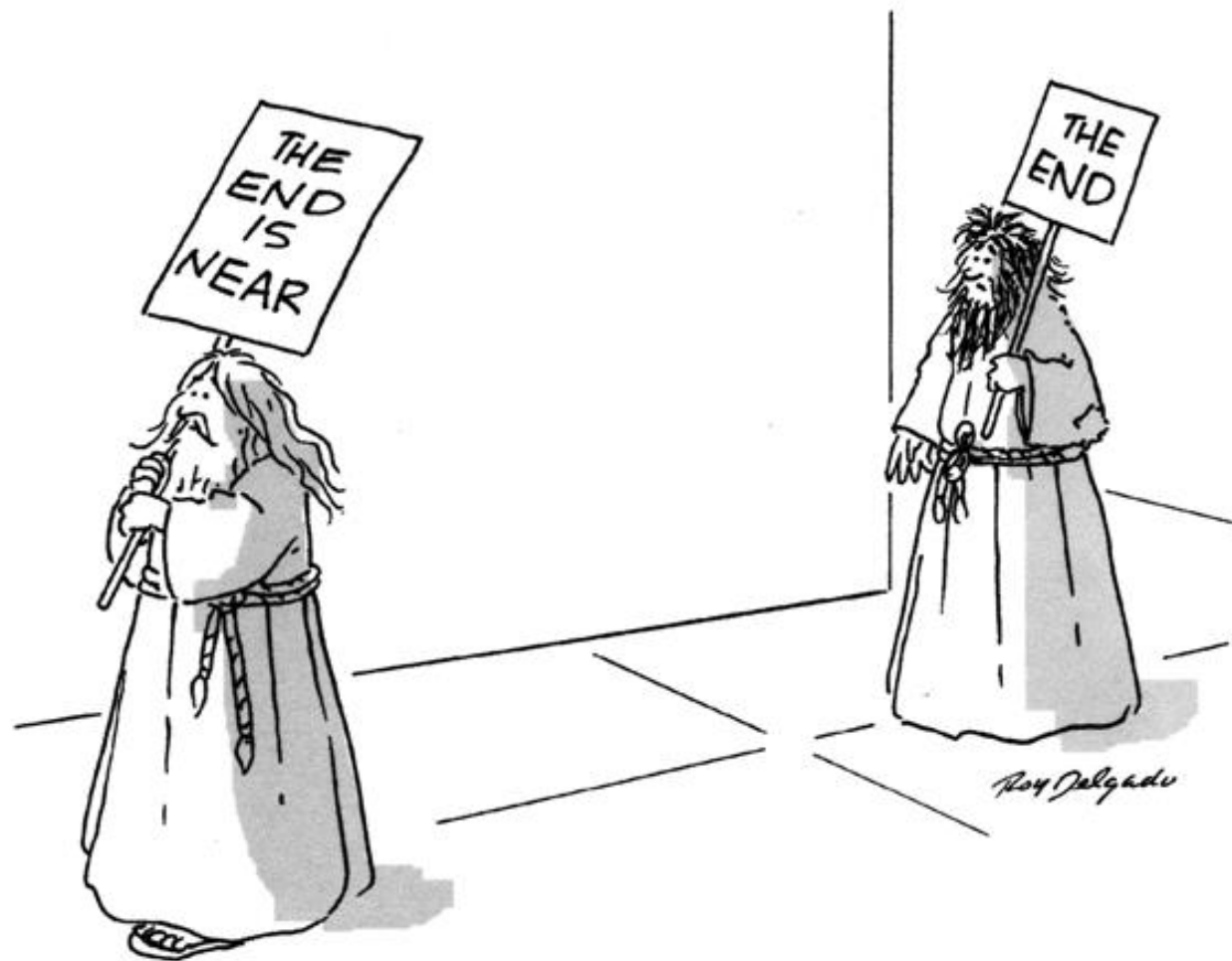
Security Operation Center



Security Operation Center

- Bezpečnostní dohledové centrum
- Detekuje bezpečnostní události a incidenty
- Obvykle neprovádí reakci na bezpečnostní incidenty

Tím to nekončí ...



PROSTOR PRO VAŠE DOTAZY

DĚKUJI VÁM ZA POZORNOST